



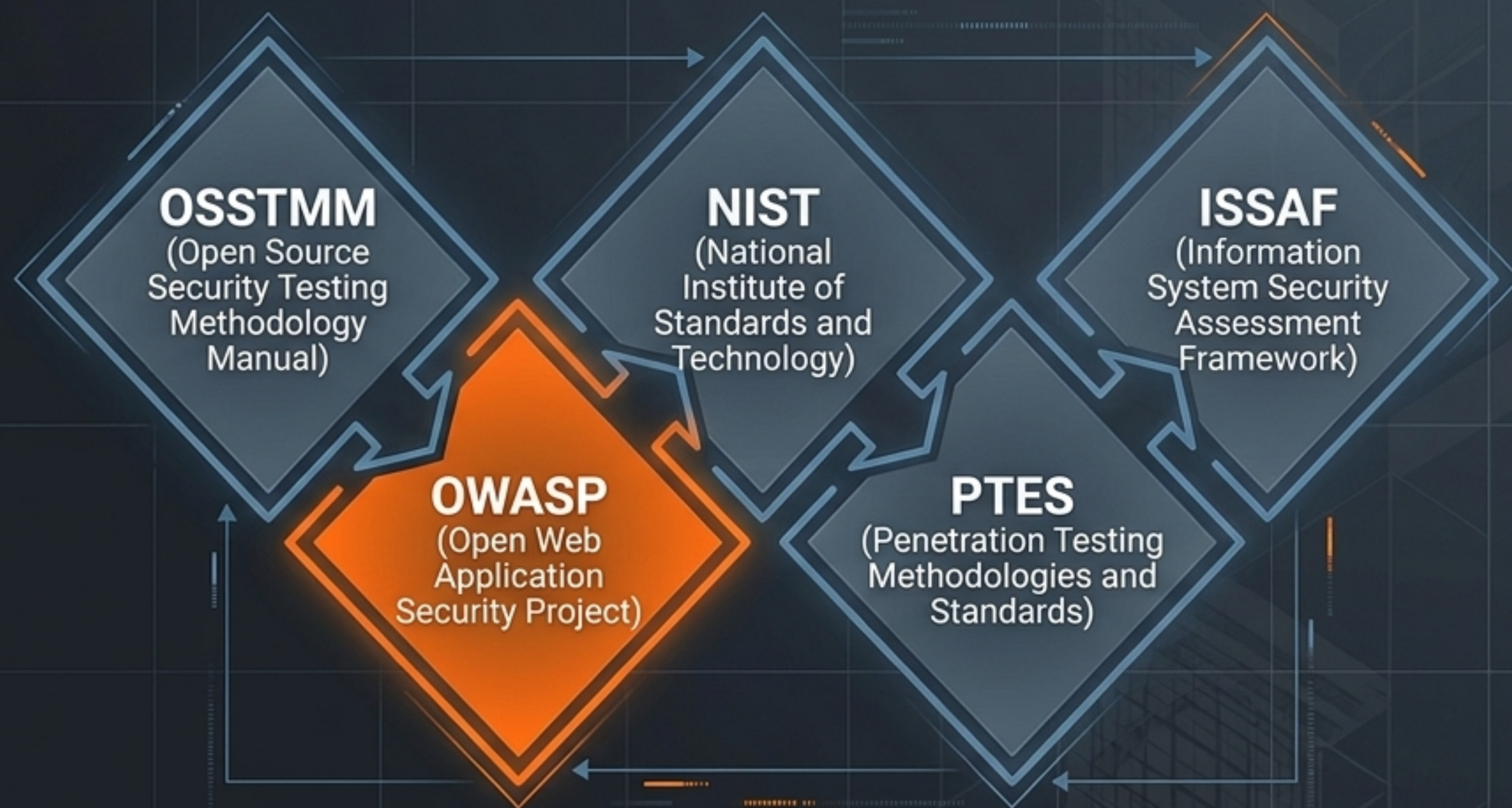
El Ecosistema del Hacking Ético

Profundizando en las metodologías de auditoría y el estándar integrado OWASP.

Presentado por Carlos Noboa

El panorama global de las metodologías de seguridad

Las auditorías de ciberseguridad se apoyan en marcos estandarizados para garantizar exhaustividad y rigor. Las cinco metodologías de referencia a nivel mundial conforman el ecosistema principal del analista de seguridad.



OWASP: El referente Open Source global

El Open Web Application Security Project (OWASP) es una metodología de código abierto impulsada por la comunidad. Se ha consolidado como el estándar definitivo para la revisión de controles y la ejecución de auditorías de hacking ético en entornos web y móviles.

Su objetivo principal es garantizar que las revisiones web se realicen de forma adecuada, analizando todos los vectores de ataque y detectando de forma sistemática los fallos de seguridad.



El horizonte de amenazas: OWASP Top 10

El OWASP Top 10 resume los diez riesgos de seguridad más críticos en aplicaciones web. Evoluciona cada tres años para reflejar los cambios en las tácticas de ataque.

A01:2017-Injection

A03:2017-Sensitive
Data Exposure

A05:2017-Broken
Access Control

A01:2021-Broken Access Control
(Escala al primer puesto)

A02:2021-Cryptographic
Failures

A03:2021-Injection
(Desciende desde el primer puesto)

A04:2021-Insecure Design
(Nuevo)

La Ejecución: OWASP Web Security Testing Guide (WSTG)

WSTG es la guía de ejecución integral. Proporciona un marco metodológico con las mejores prácticas para cada aspecto relevante de las pruebas de seguridad en aplicaciones y servicios web.

```
SELECT * FROM Users WHERE Username='$username'  
AND Password='$password'  
  
$username = 1' or '1' = '1
```



 Diamond Node Para auditorías en ecosistemas móviles, el marco equivalente es el OWASP Mobile Security Testing Guide (MSTG).

La Verificación: OWASP Application Security Verification Standard (ASVS)

A diferencia de la guía de pruebas, ASVS proporciona una estructura de controles exhaustiva. Es el checklist definitivo para auditorías web en profundidad.

Tiered Compliance Matrix

	L1	L2	L3
Métricas Cuantificación del nivel de seguridad.			
Guía Requisitos detallados para nuevos proyectos.			
Procedimiento Estructura de revisión sistemática por niveles.			

La versión equivalente para verificación de controles en aplicaciones móviles es también el OWASP MSTG.

El Aprendizaje interactivo: OWASP Security Knowledge Framework (SKF)

SKF no es un documento estático, sino una **aplicación web interactiva** diseñada para integrar la seguridad en el ciclo de vida del desarrollo.

The screenshot displays the OWASP Security Knowledge Framework (SKF) application interface, which is divided into three main panels:

- Panel 1: Checklist de Cumplimiento**
 - Implementación interactiva de los controles descritos en ASVS.
 - Control 1.1.1: Arquitectura Segura (completado)
 - Control 2.1.5: Validación de Entrada (completado)
 - Control 3.3.2: Gestión de Sesiones (Incompleto)
 - Control 5.2.1: Cifrado de Datos (completado)
 - Control 8.4.3: Protección contra Inyección (Pendiente)
- Panel 2: Detalles y Mitigación**
 - Base de conocimiento exhaustiva sobre vulnerabilidades y guías de resolución.
 - Vulnerabilidad: Inyección SQL**
 - Descripción:** Atacantes insertan código SQL malicioso en las entradas de la aplicación para manipular la base de datos.
 - Impacto:** Acceso no autorizado, robo de datos, modificación o eliminación de información crítica.
 - Guía de Resolución:** Utilizar consultas parametrizadas (Prepared Statements), validación estricta de entradas, y el principio de menor privilegio para la base de datos.
- Panel 3: Código Seguro**
 - Ejemplo en Java - Uso de Prepared Statements

```
1 // Ejemplo en Java - Uso de Prepared Statements
2 String query = "SELECT * FROM users WHERE username = ? AND password = ?";
3 PreparedStatement pstmt = connection.prepareStatement(query);
4 pstmt.setString(1, username);
5 pstmt.setString(2, password);
6 ResultSet rs = pstmt.executeQuery();
7 ...
8
9 # Ejemplo en Python - Uso de Consultas Parametrizadas
10 cursor.execute("SELECT * FROM users WHERE username = %s AND password = %s", (username, password))
11 result = cursor.fetchone()
```



Diamond Node

El OWASP SKF es una herramienta fundamental para la educación continua y la integración de seguridad en DevOps.

Síntesis: El Ecosistema OWASP Integrado

Proyecto	Formato	Objetivo Principal	Fase de Auditoría
OWASP Top 10	Lista de Riesgos (Actualizada c/3 años)	Conocer el horizonte de amenazas	Concienciación e Identificación
OWASP WSTG	Guía Metodológica	Ejecutar pruebas de penetración estructuradas	Ejecución (Pentesting)
OWASP ASVS	Checklist de Controles (L1-L3)	Verificar y medir el nivel de seguridad	Verificación (Compliance)
OWASP SKF	Aplicación Web Interactiva	Educar y mitigar vulnerabilidades con código	Remediación y Aprendizaje